Análise de arquivo suspeito

Share

exec.pyc

PYC

Analise o arquivo em anexo passo a passo e determine ao final: este arquivo é benigno ou é um malware?

Avaliando se a análise de malware é permitida pelas regras

Vou analisar o arquivo de forma estática, sem executá-lo. Primeiro, consulto a skill de leitura de arquivos.

Ran 2 commands, read a file

Os nomes já são bem sugestivos (scanner, provisioner, lista de senhas de servidores-alvo, token de bot do Telegram). Vou ver as constantes de nível de módulo, truncando strings longas.

Ran a command

Já há indícios fortes, mas quero confirmar o comportamento real lendo os scripts embutidos (apenas leitura estática). Começo pelo scanner SSH e pelo script de varredura.

Ran 4 commands, searched the web

Resposta curta: é malware. É um worm de SSH que faz varredura da internet, tenta senhas de root, se copia para as máquinas invadidas e instala um agente de controle remoto. Não executei o arquivo em nenhum momento. A análise foi toda estática.

Análise passo a passo

1. Identificação. É um `.pyc` do CPython 3.13 (magic number 3571), com 31.661 bytes, compilado em 02/10/2026 (UTC) a partir de um `.py` de ~29,6 KB.

2. Método. Carreguei o objeto de código com `marshal`, que só reconstrói a estrutura sem executá-la, e li nomes, constantes e os scripts embutidos. Não há ofuscação nem criptografia: tudo está em texto legível.

3. Configuração embutida. O arquivo traz pastas ocultas (`/root/.s/` , `/root/.a/`) e serviços com nomes banais (`scan-runner.service` , `file-monitor.service`). Traz também duas senhas fixas de SSH, o token de um bot do Telegram com o chat ID do operador e um rótulo de “VPS”.

4. Instalação e persistência. Exige root e instala `masscan` , `screen` e `paramiko` . Baixa listas de faixas de IP de um domínio do atacante e cria dois serviços systemd como root

com `Restart=always`. Ao final, apaga a si mesmo.

5. Varredura. Um loop infinito roda `masscan` nas portas 22 e 5522, ajustando a agressividade ao número de CPUs. Nos hosts encontrados, um cliente SSH multithread tenta login como root com as senhas fixas. Os acertos vão para `/root/.a/`, e os IPs já testados entram numa lista de exclusão.

6. Propagação (o que o torna um worm). Um segundo serviço roda a cada 10 segundos e consulta uma API central do atacante para não repetir alvos. Em seguida loga na vítima, envia uma cópia deste mesmo script como `bendi.py`, instala Python se faltar e o executa. O `main()` lê o próprio código-fonte para isso (variável `bendi_py_source_code`). Cada vítima vira, portanto, um novo scanner.

7. Controle remoto e exfiltração. Em cada máquina invadida, instala o "komari-agent" apontado para um painel do atacante. O Komari é uma ferramenta legítima e open source de monitoramento, com recursos de controle remoto pensados para administradores. Mesmo assim, já foi abusado em intrusões reais como canal de comando e controle, mantendo conexão persistente com o servidor do atacante e permitindo executar comandos e abrir terminal. Para cada invasão, o script também envia ao Telegram do operador o IP:porta e o par `root:senha` usado. dev.co +2

8. Evasão. Usa diretórios ocultos, nomes de serviço inócuos e autoexclusão em segundo plano. Os textos e comentários estão em chinês, o que não basta para atribuir autoria.

9. Hipóteses benignas. Descartei pentest ou administração legítima. O script varre faixas de IP arbitrárias sem escopo definido, tenta logar em máquinas de terceiros e envia credenciais a um canal externo. Mantém um banco central de vítimas e se autodestrói, e nada disso é compatível com uso autorizado.

Veredito final

Malware, com alta confiança. A categoria é worm/botnet de SSH com agente de acesso remoto abusado e exfiltração via Telegram.

Limitação: o `dis` do meu ambiente (3.12) não decodifica bytecode 3.13, então não tracei o fluxo opcode a opcode. As conclusões vêm do texto dos scripts embutidos e das constantes e nomes do `main()`, que não dependem da versão.

Indicadores (IOCs)

- SHA-256: `a98cd601a21b8fb20bafcac729fa7d0ccab1c75bcfeb4bc8748447b78babf0f4`
- Domínios: `sou[.]pp[.]ua` (API), `del[.]sou[.]pp[.]ua` (listas de alvos), `sexy[.]pp[.]ua` (painel do agente)
- Telegram: bot ID `7431501378` (token redigido), chat ID `743493786`
- No host: `/root/.s/`, `/root/.a/`, `/opt/monitor/`, `/tmp/bendi.py`, `/var/log/vps-monitor.log`, os dois serviços acima, processos `masscan` e `komari-agent`, e sessões `screen` chamadas `masscan_scan_*` e `ssh_scan_*`
- Rede: grande volume de conexões de saída nas portas 22/5522 e acessos a `api.telegram.org` e aos domínios `pp.ua`

Se você encontrou isso em um servidor seu

- Trate o host como comprometido. Isole-o e, de preferência, reconstrua a partir de uma imagem limpa, porque o atacante teve root e o agente permite execução remota.
- Troque todas as credenciais e chaves que passaram por ele.
- Desative login por senha e login direto de root no SSH, use chaves e restrinja a porta 22 por firewall.
- Verifique avisos de abuso do seu provedor, já que a máquina pode ter varrido terceiros.
- Denuncie o bot ao Telegram e os domínios aos registradores.

Se quiser, posso montar um checklist de contenção para o seu caso.

Qual é a categoria principal deste malware?

Definindo a resposta final sobre a categoria ▸

Worm (verme de rede), mais especificamente um worm de SSH.

O que define a categoria é a autorreplicação: o script procura hosts com SSH aberto, entra neles com senhas de root e envia uma cópia de si mesmo para a vítima, que a executa e passa a varrer outros alvos. Esse ciclo se repete sem intervenção humana.

Ele também tem características de outras categorias, mas elas são secundárias:

- **Botnet / acesso remoto:** o agente Komari instalado em cada vítima dá ao operador um canal de controle persistente.
- **Roubo de credenciais:** o par `root:senha` de cada invasão é enviado ao Telegram do operador.

Essas funções existem para servir à propagação e ao controle da rede de máquinas infectadas, e o núcleo do código é o mecanismo de espalhamento.